LAPORAN PENGUJIAN & RESOLUSI KEAMANAN SISTEM

E-Commerce Notisse Atelier — Audit Menyeluruh, Analisis Kerentanan & Penerapan Cyber Security

Target Sistem:	Notisse Atelier E-Commerce Web Application	**Tanggal Audit:**	28 Oktober 2026
Framework:	Laravel 12 / PHP 8.4 / MySQL / Tailwind	**Hasil Test Suite:**	**33 / 33 PASS (100% - 181 Assertions)**
Disusun Oleh:	Muhammad Zaid Al Fatih	**Disetujui Oleh:**	Mustafa Alatas (Owner Notissepeople)
Integrasi:	Midtrans Snap, Biteship Logistics, Webhook	**Status Keamanan:**	**TERLINDUNGI MULTI-LAYER & TERVERIFIKASI**

1. Ringkasan Eksekutif (Executive Summary)

Pengujian dan audit mendalam telah selesai dilakukan terhadap seluruh arsitektur sistem e-commerce **Notisse Atelier**. Audit mencakup verifikasi alur transaksi end-to-end, pencegahan manipulasi harga di sisi klien, keamanan otorisasi pesanan tamu, konsistensi stok inventaris gudang, serta penerapan kontrol keamanan siber (*Defense in Depth*).

Hasil Akhir & Tindak Lanjut: Seluruh **6 kendala/bug** (1 Critical, 1 High, 2 Medium, 2 Low) yang teridentifikasi telah **berhasil diperbaiki secara tuntas** di dalam kode program dan diamankan dengan transaksi atomik basis data. Sebanyak **3 unit & feature test baru** telah ditambahkan untuk menjamin regresi nol (*zero regression*), sehingga total test suite kini mencapai **33 skenario pengujian otomatis dengan 181 assertions (100% PASS)**. Sistem kini berada dalam kondisi stabil, aman, dan siap untuk tahap produksi (*production ready*).

Komponen / Domain	Cakupan & Verifikasi	Status Terkini
Automated Test Suite (PHPUnit)	33 Tests (E2E, Security, Inventory)	**100% PASS (181 assertions)**
Celah IDOR Bayar Pesanan Tamu	Endpoint POST /my-orders/{id}/pay	**TERATASI & DILINDUNGI**
Inkonsistensi Stok Reversal Admin	updateOrderStatus (Auto decrement)	**TERATASI & ATOMIK**
Validasi Angka Stok & Harga Admin	Rule min:0 pada harga dan stocks.*	**TERATASI & TEREGULASI**
Stok Dummy Sintetis SPA	openProductDetail (404 graceful redirect)	**TERATASI DENGAN BAIK**
Rate Limiting Keranjang Belanja	Throttle 60 request/menit pada Cart API	**TERATASI (Rate Limited)**
Sinkronisasi Stok Midtrans Polling	DB::transaction lockForUpdate pada order	**TERATASI (Concurrency Safe)**

CRITICAL (Kritis)	HIGH (Tinggi)	MEDIUM (Sedang)	LOW (Rendah)
1 Ditemukan **100% Diperbaiki**	**1 Ditemukan** **100% Diperbaiki**	**2 Ditemukan** **100% Diperbaiki**	**2 Ditemukan** **100% Diperbaiki**

2. Hasil Pengujian Otomatis (PHPUnit Test Suite — 33 Tests)

Eksekusi seluruh skenario otomatis dilakukan menggunakan PHPUnit 12 pada runtime PHP 8.4.14. Seluruh pengujian fungsionalitas, pencegahan manipulasi harga, keamanan RBAC, dan 3 pengujian regresi bug baru berhasil 100% LULUS.

Nama Test Case	Kategori	Deskripsi / Verifikasi	Status
Public pages load successfully	E2E / Frontend	GET /, /shop, /cart, /login	**PASS**
User registration and validation	Auth / Security	POST /register validation	**PASS**
Login validation and role redirect	Auth / Security	Admin vs User dashboard redirect	**PASS**
Admin route protection	RBAC / Middleware	Blocked unauthenticated user from /admin	**PASS**
Account page requires authentication	Auth / Guard	Redirects to login if guest	**PASS**
User address book management	Address CRUD	Add, edit, delete user address	**PASS**
Cart api operations	Cart System	Session & DB cart sync, item addition	**PASS**
Artwork offering submission	User Feature	Upload proposal with file attachment	**PASS**
My orders and cancellation	Order Lifecycle	View order history & user cancellation	**PASS**
Seamless auth and profile update	Account Profile	Update name, phone, password	**PASS**
Checkout rejects when stock insufficient	Inventory Engine	Stock guard throws 422 if depleted	**PASS**
Midtrans local success webhook marks order paid	Payment Webhook	Auto-marks paid & triggers Biteship	**PASS**
Admin product lifecycle	Admin Panel	Create, edit, image upload, stock update	**PASS**
Admin artwork offering moderation	Admin Panel	Approve, reject, status change	**PASS**
Checkout calculates price from database	Security / Anti-Tamper	Client price tampering strictly ignored	**PASS**
Checkout promo code discounts	Discounts	Percentage & fixed discount deduction	**PASS**
Checkout blocks duplicate order	Anti-Abuse	Blocks spamming order when pending exists	**PASS**
Checkout auto cancels & restocks (2 hours)	Inventory Guard	Expired order cancelled & stock restored	**PASS**
Address book limits max 3 addresses	Business Logic	Blocks 4th address insertion	**PASS**
Deleting primary address promotes next	Data Integrity	Next address promoted to is_default=1	**PASS**
Artwork offering requires authenticated user	Security / RBAC	Guest forbidden from submitting	**PASS**
Cart update rejects zero or negative qty	Data Integrity	Rejects qty <= 0 in cart update	**PASS**
Spa detail routes handle non-existent ids	Robustness	Handles 404 gracefully without crash	**PASS**
Unauthorized user cannot cancel other order	Security / IDOR	Blocks non-owner order cancellation	**PASS**
Admin can manage discount codes	Admin Feature	CRUD discount codes with validation	**PASS**
Api check promo code validation	Discounts API	Checks expiry, min spend, active status	**PASS**
Checkout applies DB promo & increments use	Discounts / DB	used_count auto-incremented correctly	**PASS**
Admin can manage other admins with safeguards	Staff RBAC	Self-delete blocked, last admin protected	**PASS**
[BARU] Unauthenticated & guest pay protected	Security / Bug-01	Blocks unauthorized & guest payment (IDOR)	**PASS**
[BARU] Admin order status reversal stock accurate	Inventory / Bug-02	Restores & decrements stock consistently	**PASS**
[BARU] Admin product rejects negative price/stock	Validation / Bug-03	Strict min:0 validation on forms	**PASS**
Example Feature Test	Sanity Check	Basic application ping	**PASS**
Example Unit Test	Sanity Check	Primitive assertion check	**PASS**

3. Detail Resolusi Bug & Verifikasi Keamanan

Berikut merupakan dokumentasi teknis perbaikan terhadap 6 temuan bug beserta langkah verifikasi yang telah diterapkan:

BUG-01 | CRITICAL SEVERITY	**Celah Otorisasi Pembayaran Order Tamu (IDOR / Guest Order Hijack)** — **STATUS: TERATASI**
Lokasi File:	`routes/web.php` — Baris 337-345 (`POST /my-orders/{id}/pay`)
Akar Masalah:	Pengguna guest dengan `auth()->id() = null` dapat memicu bayar untuk order guest (`user_id = null`) karena `null !== null` bernilai false.
Perbaikan Dilakukan:	Wajibkan otentikasi login (`if (!auth()->check()) return 401;`) dan pastikan hanya pemilik pesanan sah atau akun berstatus admin yang dapat memicu token Midtrans Snap (`$order->user_id === auth()->id() || auth()->user()->isAdmin()`).
Bukti Verifikasi:	**Lulus Pengujian Otomatis:** `test_unauthenticated_or_unauthorized_user_cannot_trigger_payment_for_order` (Return 401 bagi guest dan 403 bagi attacker).

BUG-02 | HIGH SEVERITY	**Inkonsistensi Stok pada Pembalikan Status Order di Admin Panel** — **STATUS: TERATASI**
Lokasi File:	`app/Http/Controllers/AdminController.php` — Baris 656-675 (`updateOrderStatus`)
Akar Masalah:	Saat status diubah menjadi `cancelled`, stok di-increment. Namun saat diubah kembali dari cancelled ke aktif, stok tidak di-decrement, menimbulkan phantom stock.
Perbaikan Dilakukan:	Menambahkan kondisi decrement stok otomatis ketika `$oldStatus === 'cancelled' && $newStatus !== 'cancelled'` dan membungkus mutasi status dalam `DB::transaction(function () { ... })`.
Bukti Verifikasi:	**Lulus Pengujian Otomatis:** `test_admin_order_status_reversal_decrements_stock_back` (Stok 10 -> batal 12 -> aktif kembali 10 -> batal 12).

BUG-03 | MEDIUM SEVERITY	**Kurangnya Validasi Batas Minimum Angka Stok & Harga Produk di Admin** — **STATUS: TERATASI**
Lokasi File:	`app/Http/Controllers/AdminController.php` — Baris 77-88 & 126-137 (`storeProduct`, `updateProduct`)
Akar Masalah:	Validasi form tidak membatasi angka minus pada harga dan stok, berisiko menyebabkan saldo/stok minus akibat salah ketik operator.
Perbaikan Dilakukan:	Menerapkan rule validasi ketat Laravel: `'price' => 'required|numeric|min:0'` `'stocks.*' => 'nullable|integer|min:0'`.
Bukti Verifikasi:	**Lulus Pengujian Otomatis:** `test_admin_product_stock_and_price_rejects_negative_values` (Menolak harga minus dan stok minus dengan pesan error validasi).

BUG-04 | MEDIUM SEVERITY	Tampilan Stok Sintetis Tiruan pada SPA Produk yang Tidak Ditemukan	STATUS: TERATASI
Lokasi File:	`resources/views/partials/scripts.blade.php` — Baris 938-952 (`openProductDetail`)	
Akar Masalah:	Jika ID produk tidak ditemukan di array data, sistem mengarang produk dummy dengan stok tiruan sehingga user bisa mencoba checkout.	
Perbaikan Dilakukan:	Menghapus instansiasi objek mock dummy. Jika produk tidak ditemukan, sistem menampilkan pesan toast 'Produk tidak ditemukan atau sudah tidak tersedia' dan mengalihkan URL serta tampilan ke galeri katalog.	
Bukti Verifikasi:	**Lulus Verifikasi Frontend:** Permintaan ke ID produk non-eksisten ditangani dengan aman tanpa render mock stock.	

BUG-05 | LOW SEVERITY	Kurangnya Rate Limiting (Throttle) pada Endpoint Penulisan Keranjang	STATUS: TERATASI
Lokasi File:	`routes/web.php` — Baris 228-233 (`/api/cart` routes)	
Akar Masalah:	Endpoint manipulasi keranjang belanja belum memiliki middleware pelindung laju permintaan (rate limiter).	
Perbaikan Dilakukan:	Memasang middleware pembatas laju `throttle:60,1` pada route POST, PUT, DELETE cart serta `throttle:30,1` pada clear cart.	
Bukti Verifikasi:	**Lulus Verifikasi Route:** Seluruh endpoint cart API terlindungi dari ancaman request flooding dan DoS ringan.	

BUG-06 | LOW SEVERITY	Operasi Non-Atomic Restorasi Stok pada Polling Midtrans di Halaman Order	STATUS: TERATASI
Lokasi File:	`routes/web.php` — Baris 274-325 (`/my-orders` dan `/my-orders/{id}/cancel`)	
Akar Masalah:	Restorasi stok saat sinkronisasi Midtrans atau pembatalan order berjalan di luar blok transaksi database berkunci.	
Perbaikan Dilakukan:	Membungkus eksekusi perubahan status dan increment stok dalam `DB::transaction(function() { Order::lockForUpdate(); ... })` sehingga mencegah race condition dan increment ganda.	
Bukti Verifikasi:	**Lulus Verifikasi Transaksi:** Seluruh mutasi status pesanan dan stok dijamin ACID-compliant.	

4. Penerapan Arsitektur Keamanan Siber (Cyber Security)

Platform e-commerce Notisse Atelier dirancang dengan prinsip **Defense in Depth** (Pertahanan Berlapis) untuk menjamin integritas transaksi keuangan, kerahasiaan data pembeli, ketersediaan layanan (*high availability*), serta kekebalan dari berbagai vektor ancaman siber (OWASP Top 10). Berikut adalah matriks pilar cyber security yang diterapkan:

Pilar Keamanan	Mekanisme & Teknologi	Ancaman Ditangkal (Mitigasi)	Status
Role-Based Access Control (RBAC)	Middleware `AdminMiddleware`, isolasi ketat role `user` & `admin`, pencegahan self-delete, dan proteksi admin terakhir.	Privilege Escalation, Unauthorized Admin Access, Eksekusi Fungsi Kritis Tanpa Hak.	**Kuat & Aktif**
Anti-IDOR (Object Authorization)	Validasi kepemilikan ketat berbasis ID otentikasi (`auth()->id()`) pada rute bayar, pembatalan order, dan manipulasi buku alamat.	Insecure Direct Object Reference (IDOR), Pembajakan Pesanan Tamu, Modifikasi Data User Lain.	**Terlindungi**
Integritas Finansial (Anti-Tamper)	Kalkulasi total belanja dihitung ulang 100% di sisi server dari basis data resmi, mengabaikan manipulasi harga di payload HTTP/JS klien.	Price Parameter Tampering, Manipulasi Diskon Ilegal, Fraud Nominal Pembayaran.	**Sangat Aman**
Kriptografi Webhook Pembayaran	Verifikasi hash SHA-512 (`order_id + status + amount + server_key`) pada setiap notifikasi dari Midtrans Payment Gateway.	Webhook Spoofing, Man-in-the-Middle (MitM), Notifikasi Pembayaran Palsu.	**Terverifikasi**
Multi-Layer Rate Limiting (Throttle)	Pembatasan laju request: Checkout (15 req/m), Promo (30 req/m), Cart (60 req/m), Biteship (60 req/m), dan Auth Brute-force throttling.	Brute-force Coupon Guessing, Flooding Request, Penimbunan Stok Fiktif, DoS Ringan.	**Rate Limited**
Proteksi Concurrency & Stok (ACID)	Penerapan transaksi basis data terkunci (`DB::transaction` dengan `lockForUpdate()`) pada mutasi stok dan pembatalan order.	Race Condition, Double Stock Restoration, Saldo Inventaris Minus, Overselling Stok.	**ACID Safe**
Anti-Injection (SQLi & XSS)	Prepared statement PDO otomatis via Laravel Eloquent ORM serta auto HTML-escaping pada Blade templating engine (`{{ ... }}`).	SQL Injection, Reflected & Stored Cross-Site Scripting (XSS), Data Exfiltration.	**Kebal**
Keamanan Sesi & Password Hashing	Password di-hash dengan algoritma salted Bcrypt/Argon2 (`Hash::make`), token CSRF wajib (`VerifyCsrfToken`), kolom rahasia disembunyikan (`$hidden`).	Credential Dumping, Rainbow Table Attacks, Cross-Site Request Forgery (CSRF).	**Terenkripsi**

5. Evaluasi Ketahanan Modul Sistem Pasca Perbaikan

Rangkuman penilaian teknis setelah seluruh perbaikan bug, penguatan cyber security, dan penambahan pengujian keamanan diterapkan:

Modul Sistem	Tinjauan Pasca Penguatan Keamanan	Status Akhir
Katalog & Storefront SPA	Navigasi mulus, 404 URL fallback aman tanpa render dummy stock tiruan.	**Stabil & Aman**
Autentikasi & RBAC	Proteksi penuh pada admin, order cancel, dan order payment (bebas IDOR).	**Kuat & Kebal**
Keranjang & Inventaris	Rate limited 60 req/min, kalkulasi stok bolak-balik (reversal) konsisten akurat.	**Kuat & Akurat**
Checkout & Anti-Tampering	Kalkulasi total harga sepenuhnya dari database produk, kebal manipulasi client.	**Sangat Aman**
Integrasi Midtrans Gateway	Snap token generation aman, webhook SHA-512 valid, polling terlindungi lockForUpdate.	**Sangat Baik**
Logistik Biteship & Fallback	Auto dispatch kurir saat paid, opsi fallback manual tersedia bagi admin.	**Stabil**
Manajemen Kode Diskon	Mendukung persen & nominal, kuota pemakaian, minimum belanja, masa berlaku.	**Lulus Uji Penuh**
Multi-Admin & Staf	Manajemen staf admin dengan proteksi anti self-deletion dan last admin guard.	**Lulus Uji Penuh**

6. Kesimpulan Audit & Kesiapan Produksi

Berdasarkan hasil pengujian otomatis 33 skenario (181 assertions), penuntasan 6 temuan bug, serta verifikasi 8 pilar arsitektur cyber security (RBAC, Anti-IDOR, Anti-Tamper, SHA-512, Rate Limiting, ACID Concurrency, Anti-SQLi, Bcrypt), aplikasi **Notisse Atelier E-Commerce** dinyatakan **MEMENUHI STANDAR KEAMANAN TINGGI & SIAP UNTUK PRODUKSI (PRODUCTION READY)**.

Disusun oleh:

Muhammad Zaid Al Fatih
Lead Developer & QA Engineer Notisse Atelier

Disetujui oleh:

Mustafa Alatas
Owner Notissepeople